

Enrico Bravi

enrico.bravi@polito.it

Module B – Social Engineering and Digital Identity

B2 – Phishing



**Politecnico
di Torino**

Department of Control and
Computer Engineering



TORSEC

Computer and Network Security Group



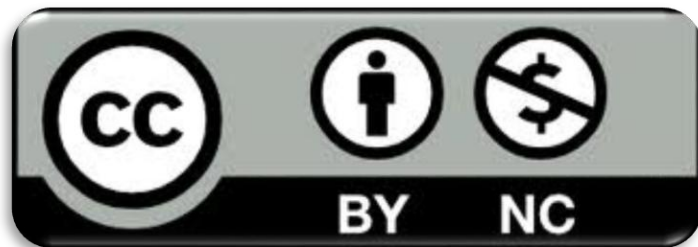
Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Nicolò Maunero (CINI / Cybersecurity National Lab). Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.



Learning Goals



- analyzing in detail the attack vectors attributable to so-called **Phishing**
- proposing possible countermeasures, identified as best practices of the so-called **Cyber Hygiene**



Cyber Hygiene



- it is the set of precautionary measures organisations and individuals do in order to help keep sensitive data safe and secure.



Social Engineering – Attack Vectors

- various types of phishing
- posing as others
- physical attacks
- cognitive type attacks



Social Engineering – Attack Vectors

- various types of phishing
 - posing as others
 - physical attacks
 - cognitive type attacks
- phishing
 - spear phishing
 - whaling
 - Business Email
Compromise (BEC)
- vishing
- smishing
- via social

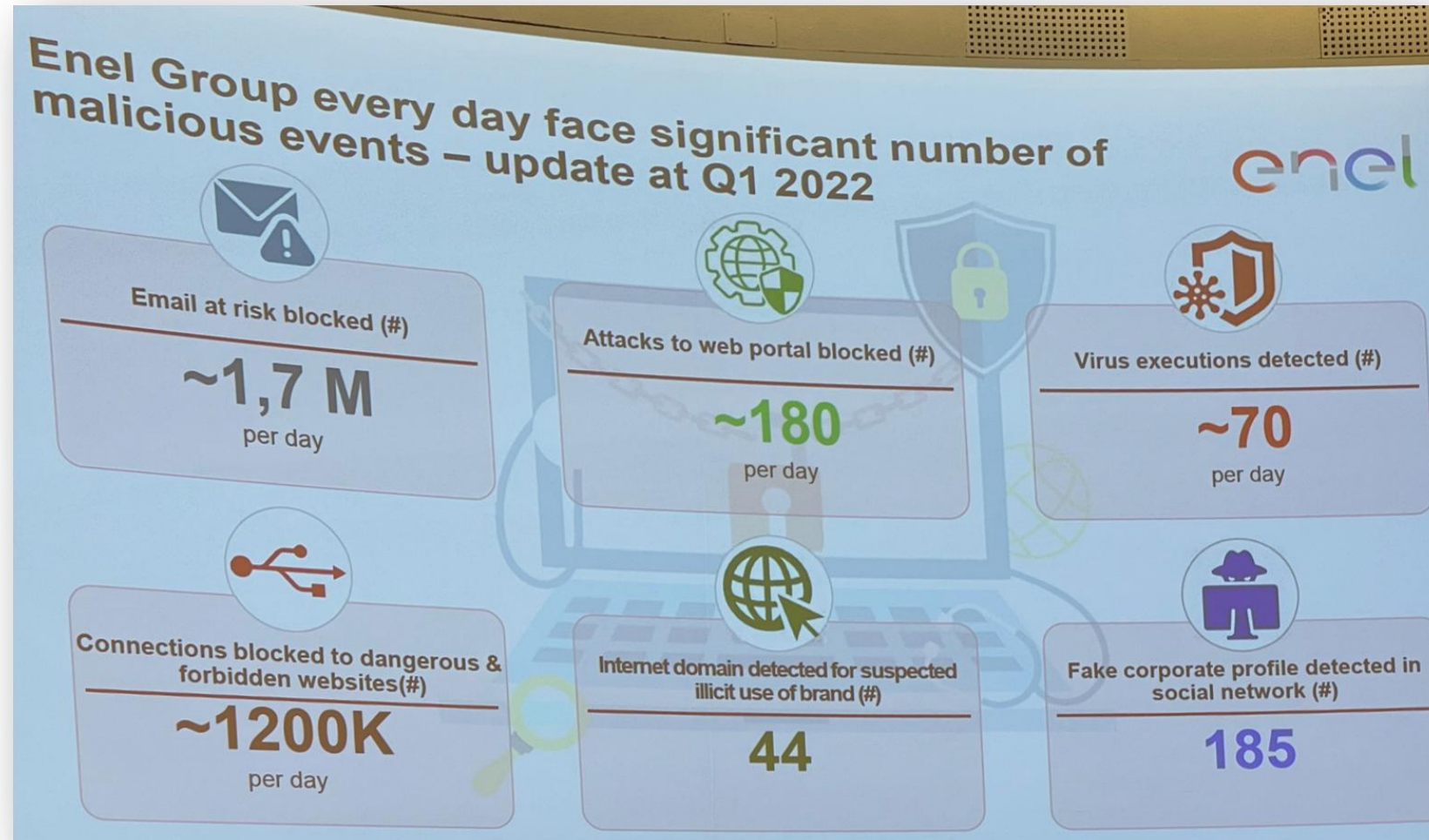


Phishing



- internet fraud in which the attacker attempts to trick the victim into:
 - provide personal information, such as login credentials, bank account and credit card details
 - click on malicious links
 - open attachments that contain malware

The Size of the Phenomenon





Phishing – How It Is Realized

- typically by sending e-mails messages, more or less targeted, that **mimic** in graphics and settings, bank or postal sites that require to send personal data
- scammers often craft email subject lines to trigger strong emotions or create urgency
- more sophisticated ones make their messages seem legitimate by using subjects the impersonated sender would realistically use, such as “Problem with your order” or “Your invoice is attached.”



Spear Phishing

- it is a **highly targeted** form of phishing aimed at a specific individual, often someone with access to **sensitive information** or special authority, like a finance manager who can transfer company funds
- using insights, attackers create messages filled with personal details that make them appear authentic
- they might pretend to be the target's boss and send a message like: "I know you're heading on vacation tonight, but could you take care of this invoice before the end of the day?"

[<https://www.ibm.com/think/topics/social-engineering#732739700>]



Whaling

- spear phishing but adopted for the **highest-value targets**
- whaling focuses on high-ranking individuals such as C-level executives (CEOs, CFOs, COOs), senior leaders, political figures, and others with the authority to approve large payments, wire transfers, or the release of sensitive information **without needing additional approval**
- these individuals are called “whales”, having access to significantly more money than the average person



Business Email Compromise (BEC)

- BEC is a type of spear-phishing attack that aims to trick **organizations** into handing over money or sensitive information
- a cybercriminal or group of attackers sends emails to **employees** that appear to come from a colleague, vendor, partner, customer, or another trusted contact
- these messages are designed to deceive recipients into paying fake invoices, transferring funds to fraudulent accounts, or revealing sensitive information such as customer data, intellectual property, or financial records.
- scammers can gain **unauthorized access** to the sender's email account, making their fraudulent messages appear more authentic.



Other Forms of Phishing (I)

- vishing
 - scammers frequently use caller ID spoofing to make their calls look like they're coming from trusted organizations or local numbers
 - these vishing calls often alarm recipients with claims of credit card issues, unpaid bills, or legal trouble, prompting them to share sensitive information or send money to “fix” the problem



Other Forms of Phishing (II)

- smishing
 - SMS phishing (smishing) relies on fraudulent text messages to deceive victims
 - scammers often impersonate mobile carriers, sending messages that promise a “free gift” or prompt users to update their credit card details.
- via social media
 - scammers may impersonate others to trick victims into sharing login credentials, enabling account takeover
 - the risk is greater for people who reuse passwords across multiple accounts.



Phishing – How to Recognize It

- Unknown or suspect sender
- Typos & Spelling errors
- Urgent request for confidential data
- spot the difference:

no-reply@microsoft.com
no-reply@rnicrosoft.com



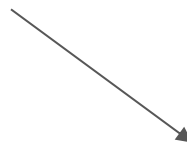


Phishing – How to Recognize It

- Unknown or suspect sender
- Typos & Spelling errors
- Urgent request for confidential data
- spot the difference:

no-reply@microsoft.com

no-reply@rnicrosoft.com



$r + n$

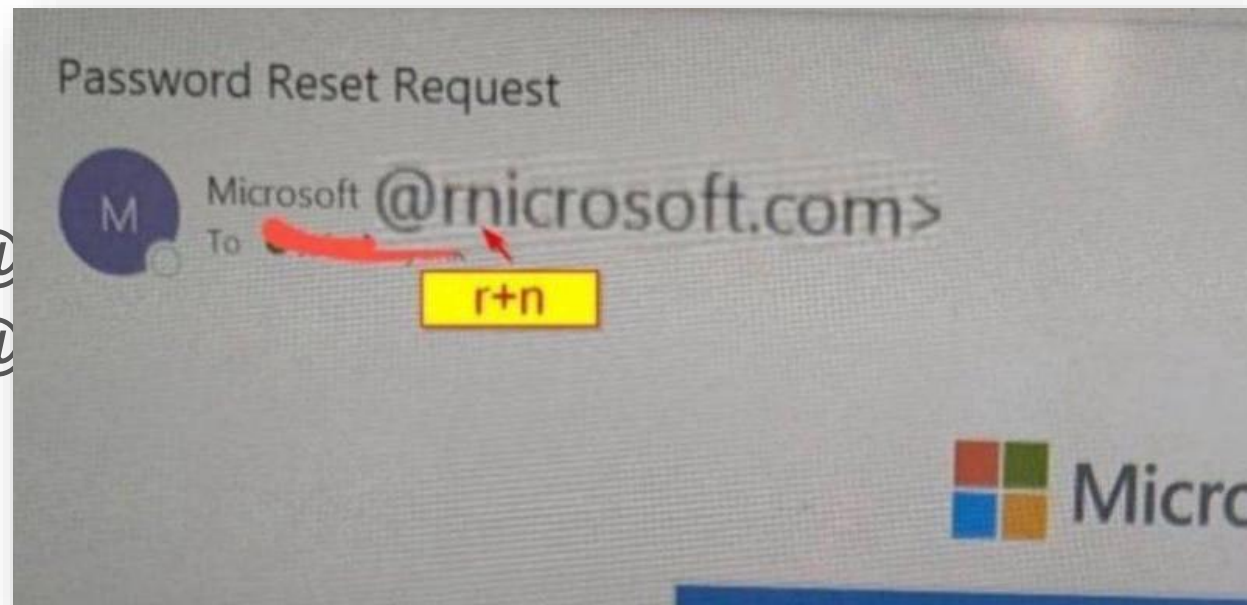
Phishing – How to Recognize It

- Unknown or suspect sender
- Typos & Spelling errors
- Urgent request for confidential data

- spot the difference:

no-reply@

no-reply@





Phishing – A Trivial Example (I)

PoliTO

Your PoliTO eMAIL Has Expired

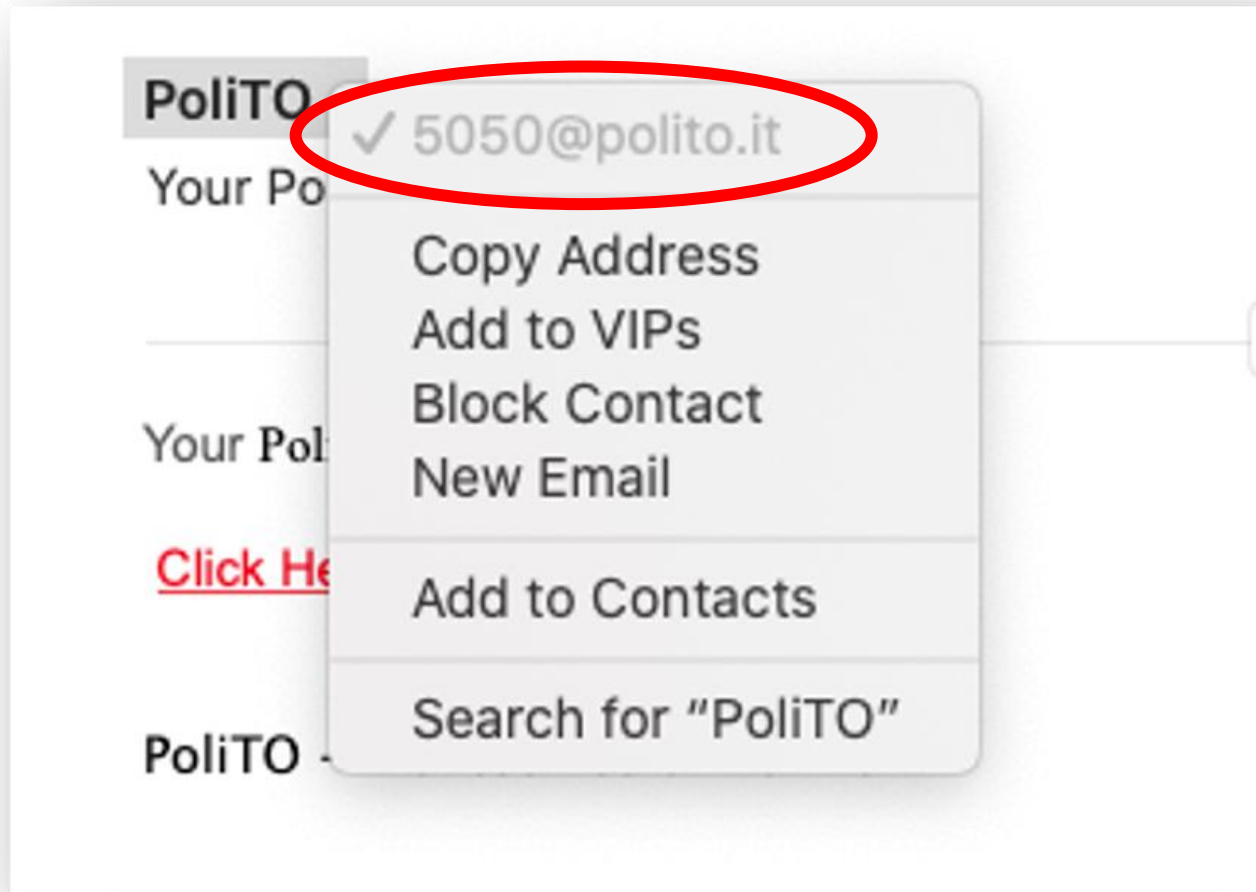
Your PoliTO eMAIL Has Expired

[Click Here To Renew](#)

PoliTO – Politecnico di Torino



Phishing – A Trivial Example (II)





Phishing – A Trivial Example (III)

PoliTO

Your PoliTO eMAIL Has Expired

Your PoliTO eMAIL Has Expired

[Click Here To Renew](#)

[https://templatesbazaar.com/fatwaonline/test/
mail.polito.it.html](https://templatesbazaar.com/fatwaonline/test/mail.polito.it.html)

PoliTO – Politecnico di Torino



Phishing (I)

- much less trivial example

Aruba.it 20 April 2020 at 08:41

Problema di pagamento
To: [REDACTED]
Reply-To: Aruba.it

aruba.it

Gentile cliente

ti informiamo che le tue informazioni di pagamento non sono valide.
ti informiamo che il dominio [ARUBA.it](https://www.aruba.it), a cui risulta collegato questo account di posta, scadrà il giorno **21/04/2020**
Desideriamo ricordare che, qualora il dominio non venga rinnovato entro tale data, questi e tutti i servizi associati, comprese le caselle di posta verranno disattivate e non potranno più essere utilizzate per l'invio e la ricezione.

COME RINNOVARE IL DOMINIO?

L'operazione di rinnovo è semplice e veloce: è sufficiente effettuare l'ordine online e relativo pagamento.

RINNOVA ORA CON UN CLICK

Per visualizzare il riepilogo dell'ordine e l'importo da pagare, puoi procedere al rinnovo da questa pagina.
Se il tuo stato non viene risolto entro 48 ore, sospenderemo definitivamente i tuoi servizi.

Grazie per la collaborazione

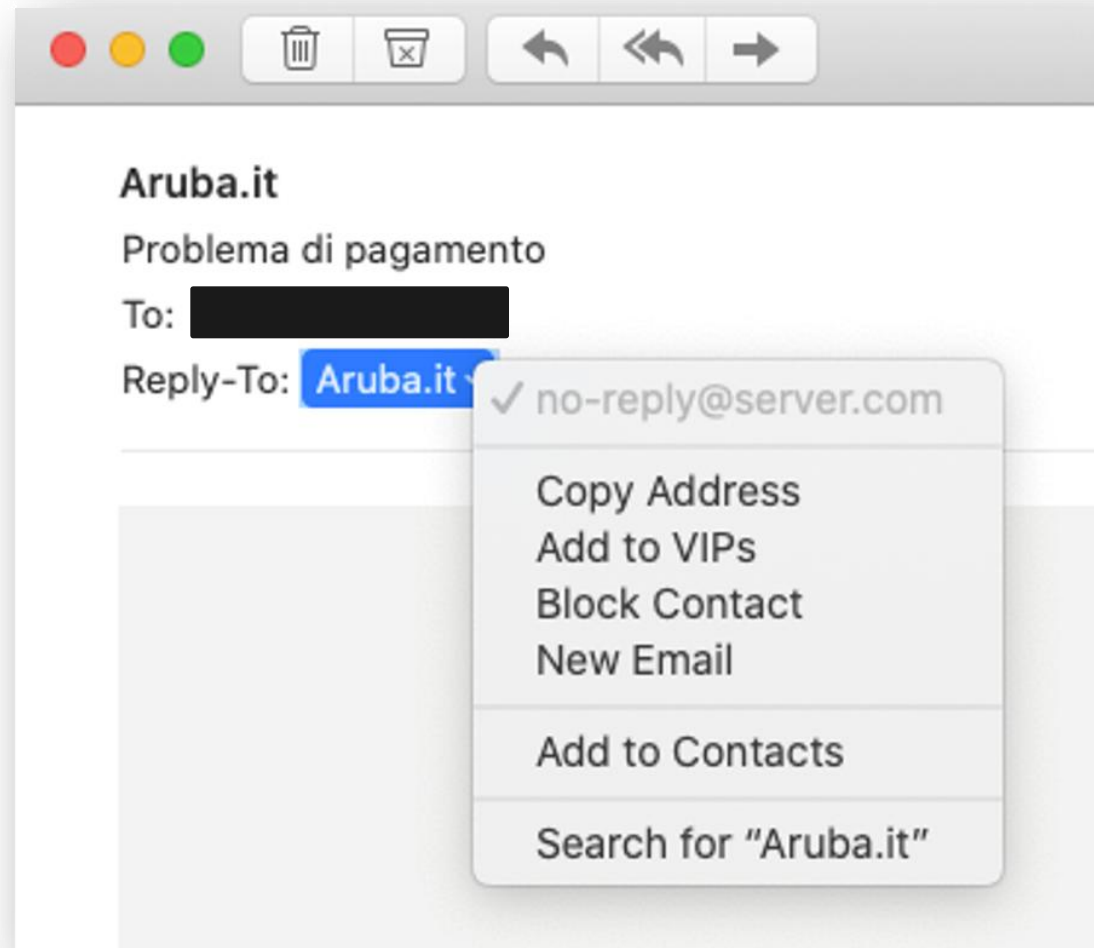
Cordiali saluti

Customer Care Aruba S.p.a.
www.aruba.it
assistenza.aruba.it

Copyright ©2020 Aruba S.p.A.- P.I. 01573850516 - All rights reserved -



Phishing (II)



Phishing (III)



Aruba.it

Problema di pagamento

To: [REDACTED]

Reply-To: Aruba.it

20 April 2020 at 08:41



aruba.it

Gentile cliente

ti informiamo che le tue informazioni di pagamento non sono valide.
ti informiamo che il dominio [ARUBA.it](http://aruba.it), a cui risulta collegato questo account di posta, scadrà il giorno **21/04/2020**
Desideriamo ricordare che, qualora il dominio non venga rinnovato entro tale data, questi e tutti i servizi associati, comprese le caselle di posta verranno disattivate e non potranno più essere utilizzate per l'invio e la ricezione.

COME RINNOVARE IL DOMINIO?

L'operazione di rinnovo è semplice e veloce: è sufficiente effettuare l'ordine online e relativo pagamento.

RINNOVA ORA CON UN CLICK

<http://rangkapselari.com/A85073P666X6T5/>

Per visualizzare il riepilogo dell'ordine e l'importo da pagare, puoi procedere al rinnovo da questa pagina.

Se il tuo stato non viene risolto entro 48 ore, sospenderemo definitivamente i tuoi servizi.

Grazie per la collaborazione

Cordiali saluti

Customer Care Aruba S.p.a.

www.aruba.it

assistenza.aruba.it

Copyright ©2020 Aruba S.p.A.- P.I. 01573850516 - All rights reserved -

An Example Targeting PoliTo

From: Supporto [REDACTED]@polito.it>
Subject: Avviso importante
Date: 13 March 2025 at 11:24:05 CET
To: <[REDACTED]@polito.it>

[RECUPERA I MESSAGGI QUI](#)



- sender looks legitimate (from @polito.it)
- link points to a domain outside PoliTo
- landing page resemble original, but with some typos

12:02 4G 44

pol-ito-it.weebly.com Hide preview

 Politecnico
di Torino

NOME UTENTE

PASSWORD

ACCEDI

Open Link
Add to Reading List
Copy Link
Share...



Very Sophisticated Example (I)

**CERT-AGID**
Computer Emergency Response Team
AGID

**AGID** | Agenzia per
l'Italia Digitale

Seguici su

cerca nel sito

Documentazione ▾ Chi siamo Contatti Strumenti ▾ Glossario ▾ Link utili ▾

Home > Notizie > Campagna di Phishing Agenzia Entrate e Riscossione

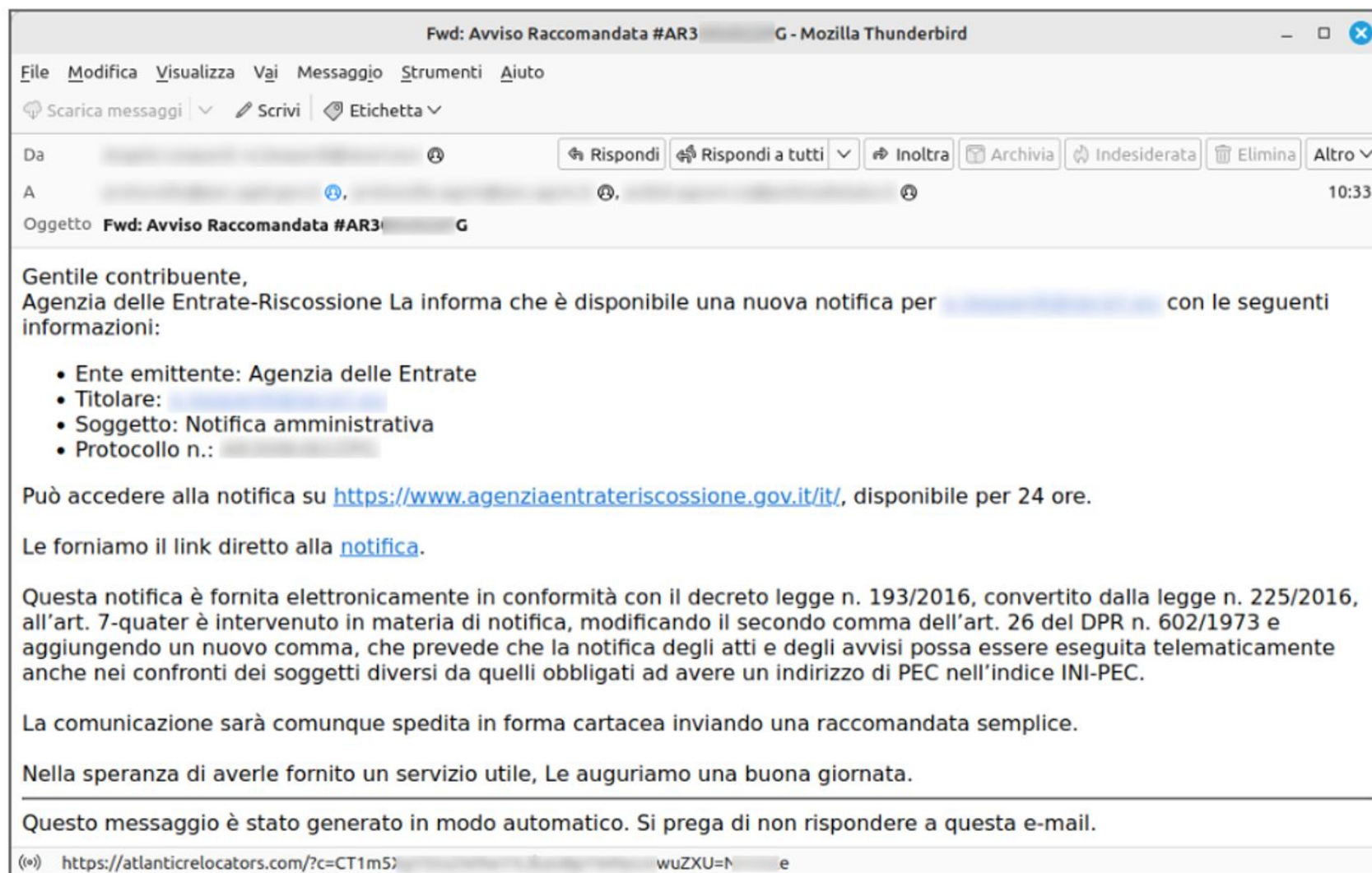
Campagna di Phishing Agenzia Entrate e Riscossione

13/11/2023

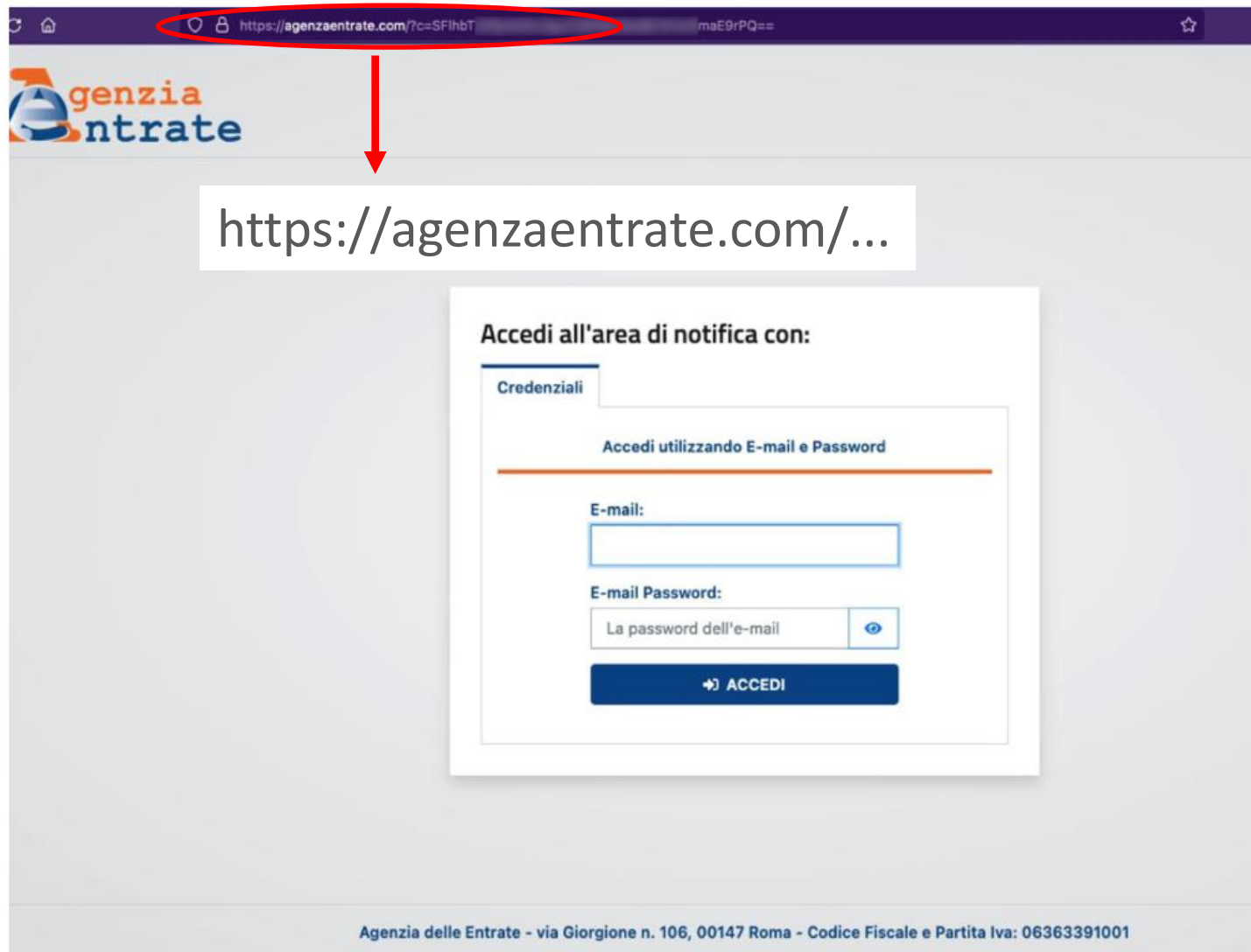
Agenzia Entrate

È in corso una campagna di phishing, rivolta indistintamente a imprese private e pubbliche amministrazioni, che sfrutta loghi e finte comunicazioni di Agenzia delle Entrate e Riscossione.

L'e-mail, con oggetto "**Avviso Raccomandata**", invita la vittima a seguire il link proposto nel corpo del messaggio per prendere atto di una **notifica**.



E-mail di phishing



Dominio di phishing



Very Sophisticated Example (IV)

- the link does not point to the real domain, but to a different one
- the attackers used a *typosquatting* technique
- registration of a common misspelling of another organization's domain



Email – Cyber Hygiene

- **ALWAYS** be suspicious of emails you receive
- **ALWAYS** be suspicious of emails that slightly surprise you, or not solicited or expected



Email – Cyber Hygiene

- At the slightest suspicion:
 - try to understand:
 - from **whom** it comes
 - on which sites you would go if you click on the indicated links
 - **never click** on the links
 - **never open of save** attachments, even if they are in formats that you might consider safe (e.g., images, PDF files, Office files)



Microsoft Office Documents

- an attacker can insert malicious code:
 - within macros
 - inside the documents without using macros, but exploiting the so-called **DDE Exploits**



Microsoft's DDE (I)

- Microsoft's Dynamic Data Exchange (DDE) is a protocol designed to allow the transportation of data between MS Office applications
- It was introduced as early as Windows 2.0 back in 1987 and provides what Microsoft once considered core functionality to the Office suite of tools
- Although DDE has now been superseded by the Object Linking and Embedding (OLE) toolkit, DDE is still supported by Office applications for backwards-compatibility



Microsoft's DDE (II)

- while that is certainly a benefit for legitimate users and uses of the protocol, the unfortunate side-effect of DDE is that it provides an avenue for attackers to exploit
- DDE allows the execution of embedded code once a victim opens such a file, without the authorization request associated with macros

[<https://www.sentinelone.com/blog/malware-embedded-microsoft-office-documents-dde-exploit-macroless>]



Email – Cyber Hygiene

- remember that no serious organization will ever ask you to submit passwords or click on a link included in an email
- adopt policies that prevent the execution of macros or VBA (Visual Basic for Applications) code present in Office source files (Word, Excel, Powerpoint)
- do not email Office source files
- install only “quality” PDF readers
- if you really must open an attachment to an Email, do so within *Virtual Machines* or *Sandboxes*, only



Virtual Machines



- a program that, through a virtualization process, creates a *virtual environment* that emulates the behaviour of a physical machine (PC, client or server) thanks to the allocation of hardware resources (portions of disk, RAM and computing resources) and in which it is possible to run applications as if they were interacting with that machine
- even if the Operating System running on the virtual machine gets compromised, the Operating System of the hosting machine would be neither affected nor damaged



Sandbox



- virtual environment, “isolated” from the rest of the computer, that allows you to run non-certified applications, download files, and visit suspicious websites without exposing the system on which the sandbox is running to risks and threats
- some examples:
 - Windows Sandbox (WSB)
 - Linux sandboxing (namespaces, chroot)
 - App sandboxing



The XZ Backdoor Case

- the XZ package is used for data compression
- it is widely used
 - adopted in the OpenSSH remote access software
- a contributor called “Jia Tan” was able to obtain maintainer-level access to the project
- exploiting the privilege Tan introduces a backdoor in the code that allowed to run arbitrary code on the victim machine when the XZ was loaded into an OpenSSH server
- it has been discovered before getting into release distributions

[<https://lwn.net/Articles/967866/>]

[<https://lwn.net/ml/oss-security/20240329155126.kjjfduxw2yrlxgzm@awork3.anarazel.de/>]